

Cloudflare Security Gap Analysis (NIST CSF)

This report reviews Cloudflare's publicly available Security Exhibit and maps it against the NIST Cybersecurity Framework's five functions to identify areas where public documentation is limited

Findings by Function:

1. IDENTIFY

- Cloudflare maintains a comprehensive, written information security program designed to ensure the confidentiality, integrity, and availability of Customer Data.
- this program is reviewed and updated, as necessary, on a regular basis to address new threats and changes in technology.
- Cloudflare's information security program complies with rigorous industry standards, including the industry standards and certifications set out at <https://www.cloudflare.com/en-gb/trust-hub/compliance-resources/> and as may be updated from time to time ("**Industry Standards** ").
- **5.3 Bug Bounty.** Cloudflare maintains an external bug bounty program to encourage responsible reporting of security issues.
- **6.1 Vendor Security.** Cloudflare assesses the security of all third-party vendors who may access Customer Data and ensures that they are bound by a written contract which imposes on them security standards no less protective of Customer Data as those set forth in this Exhibit.
- **6.2 Risk Assessments.** Cloudflare performs regular risk assessments to identify and remediate potential threats to its business and technology.
- **7.1 Scanning & Patching.** Cloudflare routinely scans its network and applications for vulnerabilities and applies security patches in a timely manner according to Industry Standards.
- **7.2 Penetration Testing.** At least annually, Cloudflare engages an independent third-party firm to perform network and web application penetration tests. Summaries of these tests are available upon request, or are also available for download by

Customer's super administrator via the dashboard at <https://www.cloudflare.com/en-gb/trust-hub/compliance-resources/>.

- **10.1 Independent Audits.** Cloudflare undergoes independent audits (such as SOC 2 Type II) at least annually to verify its security controls.
- **10.2 Report Availability.** Upon request, Cloudflare will provide copies of its most recent audit reports (e.g., SOC 2 Type II), certifications, and attestations. These documents are also available for download by Customer's super administrator via the dashboard at <https://www.cloudflare.com/en-gb/trust-hub/compliance-resources/>.
- **10.3 Transparency Reports.** Cloudflare publishes regular Transparency Reports on its website detailing government requests for data, ensuring that Customer stays informed about third-party legal processes.

2.PROTECT

- Cloudflare designs its controls to prevent unauthorized or accidental access, acquisition, destruction, loss, deletion, disclosure, or alteration or use of Customer Data.
- Cloudflare operates on a "Zero Trust" basis, meaning Cloudflare does not automatically trust any user or device, even inside its own network.
- **2.1 Least Privilege.** Access to Cloudflare systems is role-based and granted on a need-to-know basis.
- **2.2 Strong Authentication.** Cloudflare verifies identity using multi-factor authentication (MFA), including physical hardware tokens where appropriate. Cloudflare does not use shared or generic login credentials.
- **2.3 Access Reviews.** Cloudflare regularly reviews employee access rights and immediately revokes access when an employee leaves or changes roles.
- **2.4 Physical Security.** Access to Cloudflare data centers and offices is strictly controlled via technical measures, including biometric scanners, and 24/7 monitoring.
- Cloudflare uses advanced cryptography to protect Customer Data both when it is being moved and when it is stored.

- **3.1 Encryption Standards.** Cloudflare encrypts Customer Data at rest and in transit using state-of-the-art protocols (such as TLS) and strong key lengths in alignment with industry best practices.
- **3.2 Key Management.** Encryption keys are protected, rotated, and managed securely, with access restricted to specific key custodians.
- **3.3 Data Localization.** Cloudflare provides tools (such as the Data Localization Suite) that allow you to control where Customer Data is inspected and stored..
- **3.4 Secure Disposal.** Upon terminating the Agreement with Cloudflare, unless otherwise specified in the Agreement as required to be retained, Customer can request for relevant Customer Data to be deleted. Cloudflare will use secure destruction methods including but not limited to crypto-shredding or degaussing as appropriate, and in accordance with relevant Industry Standards to ensure Customer Data cannot be recovered.
- **4.1 Perimeter Defense.** Cloudflare leverages Cloudflare Technology such as Magic Transit and DDoS protection to absorb malicious traffic and shield Cloudflare's internal systems.
- **4.2 System Hardening.** Cloudflare hardens its servers by disabling unnecessary features, securing external connections, and changing default passwords before production use.
- Cloudflare integrates security into its software development process.
- **5.1 Secure Development.** Cloudflare follows a Secure Software Development Life Cycle (SDLC) that includes code reviews and testing, aligned with best practices such as the OWASP Top 10 (found at <https://www.owasp.org/>).
- **5.2 Separation of Environments.** Cloudflare keeps its development, test, and production environments separate and never uses production data in non-production environments without obfuscation.

3.DETECT

- **4.3 Monitoring & Logging.** Cloudflare monitors its network 24/7/365. Cloudflare logs activity, as necessary, to detect suspicious behavior or unauthorized changes, and protects these logs from tampering.

4.RESPOND

9.1 Response Policy. Cloudflare maintains a tested incident management policy to handle security events effectively.

9.2 Breach Notification. If Cloudflare discovers or is notified of a breach of security, which results in unauthorized access, acquisition, disclosure, or use relating to any Customer Data (“**Data Breach**”), Cloudflare will:

- (a) notify Customer of the Data Breach without undue delay;
- (b) investigate and mitigate the effects of the Data Breach; and
- (c) provide reports on the incident and Cloudflare’s remediation efforts.

5.RECOVER

8.1 Resilience. Cloudflare maintains a documented business continuity and disaster recovery (“**BC&DR**”) plan to enable Cloudflare to implement business continuity arrangements promptly.

8.2 Redundancy. Cloudflare’s infrastructure is geographically distributed and redundant (including power and internet connectivity) to minimize interruptions to the Services.

8.3 Testing and Auditing. Cloudflare tests and updates its BC&DR plan at least annually. At least annually, the BC&DR plan is audited by independent third-party assessors.

GAPS IDENTIFIED AND RECOMMENDATIONS:

Function	Gap	RECOMMENDATIONS
DETECT	Limited detail about how detected security events are analyzed, prioritized, or escalated	Publish a summary of the security event triage process — e.g., severity levels used, average time from detection to escalation, and what "prioritization" criteria mean in practice.
RESPOND	Breach notification is described as occurring "without undue delay," but a specific timeframe is not provided in the reviewed material	Specify a concrete notification timeframe (e.g., "within 72 hours of discovery") instead of the vague phrase "without undue delay," so customers know exactly what to expect.
RESPOND	Cloudflare states that its incident-management policy is tested, but the reviewed material provides limited information about how it is tested	Publish how often and in what way the incident-management policy is tested (e.g., tabletop exercises, simulated breach drills) and how frequently, similar to how they disclose BC&DR testing frequency.
RECOVER	Limited information is provided about expected recovery timeframes following a disruption	Define target recovery metrics such as RTO (Recovery Time Objective) and RPO (Recovery Point Objective) so customers know how quickly service would be restored after a disruption.
RECOVER	The BC&DR plan is tested and independently audited annually, but the reviewed material provides limited detail about testing methods, scenarios, and results	Share a summary of BC&DR test scenarios used and high-level results (without disclosing sensitive details), to give customers confidence the plan actually works in practice.

CONCLUSION:

Overall, Cloudflare demonstrates strong documentation in Protect and Identify, but could improve transparency in Detect, Respond, and Recover to build greater customer trust